

STATE OF NEW YORK

1961--A

2025-2026 Regular Sessions

IN SENATE

January 14, 2025

Introduced by Sen. GONZALEZ -- read twice and ordered printed, and when printed to be committed to the Committee on Internet and Technology -- recommitted to the Committee on Internet and Technology in accordance with Senate Rule 6, sec. 8 -- committee discharged, bill amended, ordered reprinted as amended and recommitted to said committee

AN ACT to amend the state technology law, in relation to establishing the "secure our data act"

The People of the State of New York, represented in Senate and Assembly, do enact as follows:

1 Section 1. This act shall be known and may be cited as the "secure our
2 data act".

3 § 2. Legislative intent. The legislature finds that information tech-
4 nology attacks and breaches have compromised governmental networks and
5 the electronically stored personal information of countless people
6 statewide and nationwide. State entities often receive such personal
7 information from various sources, including the data subjects them-
8 selves, other state entities, and the federal government. Additionally,
9 state entities use such personal information to make determinations
10 regarding data subjects. New Yorkers deserve to have their personal
11 information in the possession of a state entity stored in a manner that
12 will withstand any attempt by a bad actor to access, alter, or prohibit
13 access to such information.

14 Therefore, the legislature enacts the secure our data act, which will
15 require state entities to employ adequate practices and systems to
16 protect the personal information from any unauthorized acquisition,
17 access, alteration or change in access.

18 § 3. The state technology law is amended by adding a new section 211
19 to read as follows:

20 § 211. Cybersecurity protection. 1. Definitions. For purposes of this
21 section, the following terms shall have the following meanings:

EXPLANATION--Matter in italics (underscored) is new; matter in brackets
[-] is old law to be omitted.

LBD05506-02-6

(a) "Breach of the security of the system" means (i) unauthorized exfiltration, acquisition, or acquisition without valid authorization, of computerized information which compromises the security, confidentiality, or integrity of state entity-maintained personal information, (ii) unauthorized access, or access without valid authorization, to state entity-maintained personal information or to an information system used for personal information, or (iii) unauthorized modification of the access permissions, including through the use of encryption, to an information system used for personal information. "Breach of the security of the system" does not include good faith acquisition of or access to personal information, or access to an information system by an employee or agent of a state entity for the purposes of the state entity; provided that the private information or information system is not used in an unauthorized manner, accessed for an unlawful or inappropriate purpose, modified to change access permissions without authorization, or subject to unauthorized disclosure. In determining whether state entity-maintained personal information or an information system used for personal information has been exfiltrated, acquired, accessed, or experienced a change in access permissions without authorization or without valid authorization, such state entity may consider the following factors, among others:

(1) indications that the information is in the physical possession and control of an unauthorized person, such as a lost or stolen computer or other device containing information;

(2) indications that the information has been downloaded or copied;

(3) indications that the information was used by an unauthorized person, such as fraudulent accounts opened or instances of identity theft reported; or

(4) indications that the information or information system was accessed without authorization or without valid authorization, including but not limited to data in information system access logs, changes modifying access to the information or information system, modification or deletion of stored information, injecting or installing malicious code on the information system, or unauthorized encryption of stored information.

(b) "Data subject" means the person who is the subject of the personal information.

(c) "Data validation" means ensuring the accuracy, quality, and validity of source data before using, importing, saving, storing, or otherwise processing data.

(d) "Immutable" means data that is stored unchanged over time or unable to be changed. For the purposes of backups, "immutable" shall mean that, once ingested, no external or internal operation can modify the data and must never be available in a read/write state to the client. "Immutable" shall specifically apply to the characteristics and attributes of a backup system's file system and may not be applied to temporary systems state, time-bound or expiring configurations, or temporary conditions created by a physical air gap as is implemented in most legacy systems, provided that immutable backups must be capable of deletion and replacement, as applicable, in accordance with the data retention and deletion policy governing the data. An immutable file system must demonstrate characteristics that do not permit the editing or changing of any data backed up to provide agencies with complete recovery capabilities.

(e) "Information system" means any good, service or a combination thereof, used by any computer, cloud service, or interconnected system

1 that is maintained for or used by a state entity in the acquisition,
2 storage, manipulation, management, movement, control, display, switch-
3 ing, interchange, transmission, or reception of data or voice including,
4 but not limited to, hardware, software, information appliances, firm-
5 ware, programs, systems, networks, infrastructure, media, and related
6 material used to automatically and electronically collect, receive,
7 access, transmit, display, store, record, retrieve, analyze, evaluate,
8 process, classify, manipulate, manage, assimilate, control, communicate,
9 exchange, convert, coverage, interface, switch, or disseminate data or
10 information of any kind or form.

11 (f) "Mission critical" means information or information systems that
12 are essential to the functioning of the state entity.

13 (g) "Segmented storage" means the method of data storage whereby (i)
14 information is partitioned or separated, with overlapping or non-over-
15 lapping protection, and (ii) such individual partitioned or separated
16 sets of information are stored in multiple physically or logically
17 distinct secure locations.

18 (h) "State entity-maintained personal information" means personal
19 information stored by a state entity that was generated by a state enti-
20 ty or provided to the state entity by the data subject, a state entity,
21 a federal governmental entity, or any other third-party source. Such
22 term shall also include personal information provided by an adverse
23 party in the course of litigation or other adversarial proceeding.

24 (i) "State entity" means any state board, bureau, division, committee,
25 commission, council, department, public authority, public benefit corpo-
26 ration, office or other governmental entity performing a governmental or
27 proprietary function for the state of New York, except:

28 (i) the judiciary; and

29 (ii) all cities, counties, municipalities, villages, towns, and other
30 local agencies.

31 2. Data protection standards. (a) No later than one year after the
32 effective date of this section, the director, in consultation with
33 stakeholders and other interested parties, which shall include at least
34 one public hearing, shall promulgate regulations that design and develop
35 standards for:

36 (i) protection against breaches of the security of the system for
37 mission critical information systems and for personal information used
38 by such information systems;

39 (ii) data backup that includes;

40 (A) the creation of immutable backups of state entity-maintained
41 personal information;

42 (B) through data validation techniques, the exclusion of unwanted data
43 from such immutable backups, including but not limited to illegal
44 content, corrupted data, malicious code, and content that breaches
45 intellectual property protections;

46 (C) prohibitions on the use of such immutable backups except for
47 conducting data validation and performing information system recovery;
48 and

49 (D) storage of such immutable backups in segmented storage;

50 (iii) information system recovery that includes creating an identical
51 copy of an immutable backup of state entity-maintained personal informa-
52 tion in segmented storage for use when an information system has been
53 adversely affected by a breach of the security of the system and
54 requires restoration from one or more backups;

55 (iv) data retention and deletion policies specifying how long certain
56 types of data shall be retained on information systems and as immutable

1 backups in segmented storage and when or under what circumstances such
2 data shall be deleted; and

3 (v) annual workforce training regarding protection against breaches of
4 the security of the system, as well as processes and procedures that
5 should be followed in the event of a breach of the security of the
6 system.

7 (b) Such regulations may be adopted on an emergency basis. If such
8 regulations are adopted on an emergency basis, the office shall engage
9 in the formal rulemaking procedure no later than the day immediately
10 following the date that the office promulgated such regulations on an
11 emergency basis. Provided that the office has commenced the formal rule-
12 making process, the regulations adopted on an emergency basis may be
13 renewed no more than two times.

14 3. Vulnerability assessments. Notwithstanding any provision of law to
15 the contrary, each state entity shall engage in vulnerability testing of
16 its information systems as follows:

17 (a) Beginning January first, two thousand twenty-seven and on a month-
18 ly basis thereafter, each state entity shall perform, or cause to be
19 performed, a vulnerability assessment of at least one mission critical
20 information system ensuring that each mission critical system has under-
21 gone a vulnerability assessment during the past year. A report detailing
22 the vulnerability assessment methodology and findings shall be made
23 available to the office for review no later than forty-five days after
24 the testing has been completed.

25 (b) Beginning December first, two thousand twenty-seven, each state
26 entity's entire information system shall undergo vulnerability testing.
27 A report detailing the vulnerability assessment methodology and findings
28 shall be made available to the office for review no later than forty-
29 five days after such testing has been completed.

30 (c) The office shall assist state entities in complying with the
31 provisions of this section.

32 4. Data and information system inventory. (a) No later than one year
33 after the effective date of this section, each state entity shall create
34 an inventory of the state entity-maintained personal information and the
35 purpose or purposes for which such state entity-maintained personal
36 information is maintained and used. The inventory shall include a list-
37 ing of all types of state entity-maintained personal information, along
38 with the source and the median age of such information.

39 (b) No later than one year after the effective date of this section,
40 each state entity shall create an inventory of its information systems
41 and the purpose or purposes for which each such information system is
42 maintained and used. The inventory shall denote those information
43 systems that are mission critical and those that use personal informa-
44 tion, and whether the information system is protected by immutable back-
45 ups and stored in a segmented manner.

46 (c) Notwithstanding paragraphs (a) and (b) of this subdivision, if a
47 state entity has already completed a state entity-maintained personal
48 information inventory or information systems inventory, such state enti-
49 ty shall update the previously completed state entity-maintained
50 personal information inventory or information system inventory no later
51 than one year after the effective date of this section.

52 (d) Upon written request from the office, a state entity shall provide
53 the office with either or both of the state entity-maintained personal
54 information and information systems inventories required to be created
55 or updated pursuant to this subdivision.

1 (e) Notwithstanding paragraph (d) of this subdivision, the state enti-
2 ty-maintained personal information and information systems inventories
3 required to be created or updated pursuant to this subdivision shall be
4 kept confidential and shall not be made available for disclosure or
5 inspection under the state freedom of information law unless a subpoena
6 or other court order directs the office or state entity to release such
7 inventory or information from such inventory.

8 5. Incident management and recovery. (a) No later than eighteen months
9 after the effective date of this section, each state entity shall have
10 created an incident response plan for incidents involving a breach of
11 the security of the system that render an information system or its data
12 unavailable, and incidents involving a breach of the security of the
13 system that result in the alteration or deletion of or unauthorized
14 access to, personal information.

15 (b) Such incident response plan shall include a procedure for situ-
16 ations where information systems have been adversely affected by a
17 breach of the security of the system, as well as a procedure for the
18 storage of personal information and mission critical backups in
19 segmented storage to ensure that such personal information and mission
20 critical systems are protected by immutable backups.

21 (c) Beginning January first, two thousand twenty-nine and on an annual
22 basis thereafter, each state entity shall complete at least one exercise
23 of its incident response plan that includes copying the immutable
24 personal information and mission critical applications from the
25 segmented portion of the state entity's information system and using
26 such copies in the state entity's restoration and recovery process. Upon
27 completion of such exercise, the state entity shall document the inci-
28 dent response plan's successes and shortcomings in an incident response
29 plan exercise report. Such incident response plan exercise report shall
30 be kept confidential and shall not be made available for disclosure or
31 inspection under the state freedom of information law unless a subpoena
32 or other court order directs the state entity to release such inventory
33 or information from such inventory.

34 6. No private right of action. Nothing set forth in this section shall
35 be construed as creating or establishing a private cause of action.

36 § 4. Severability. The provisions of this act shall be severable and
37 if any portion thereof or the applicability thereof to any person or
38 circumstances shall be held to be invalid, the remainder of this act and
39 the application thereof shall not be affected thereby.

40 § 5. This act shall take effect immediately.